



Introducción al Marco Legal y Auditorías de Ciberseguridad



Con la colaboración:





Directiva NIS2 y su aplicación en OT

Módulo 2

Directiva NIS2 aplicada a entornos OT

¿Qué es la NIS2?

- La Directiva NIS2 (UE) 2022/2555 es una norma legal europea que refuerza la ciberseguridad en **entidades esenciales e importantes** que prestan servicios críticos para la sociedad y la economía.
- Sustituye a la NIS1 (2016) y expande su alcance tanto en sectores como en obligaciones.

¿Por qué es relevante para OT?

- Porque afecta directamente a la operación, mantenimiento y gobernanza de sistemas industriales: plantas de energía, agua, transporte, química, etc. Todo aquello que usa redes industriales, SCADA, PLCs, sensores, DCS, etc.

Directiva NIS2 aplicada a entornos OT

- La **Directiva NIS2 (UE 2022/2555)** establece dos categorías de entidades obligadas a cumplir con sus exigencias de ciberseguridad:

- ◆ **Entidades esenciales**
- ◆ **Entidades importantes**

- La distinción se basa principalmente en **el tipo de actividad que desempeñan y su impacto potencial en la sociedad o la economía** en caso de incidente.

Directiva NIS2 aplicada a entornos OT

Entidades esenciales

¿Qué son?

Organizaciones que operan en **sectores considerados críticos** para el funcionamiento básico de la sociedad, la economía o la seguridad nacional.

Sectores cubiertos (Anexo I de NIS2):

- Energía (electricidad, gas, petróleo)
- Transporte (ferroviario, aéreo, marítimo)
- Banca y mercados financieros
- Salud (hospitales, laboratorios, fabricantes farmacéuticos)
- Abastecimiento y saneamiento de agua
- Infraestructura digital (DNS, proveedores cloud críticos)
- Administración pública (en determinados casos)

¿Por qué son esenciales?

Porque un ciberataque contra ellos podría generar **disrupciones graves a escala nacional o europea**, afectando servicios vitales o causando daños a gran escala.

Directiva NIS2 aplicada a entornos OT

Entidades importantes

¿Qué son?

Empresas que, sin ser críticas, desempeñan actividades relevantes que pueden tener un impacto significativo en la economía, la cadena de suministro o sectores estratégicos.

Sectores cubiertos (Anexo II de NIS2):

- Producción y distribución de alimentos
- Fabricación de productos críticos (semiconductores, químicos, maquinaria)
- Servicios postales y mensajería
- Proveedores de servicios digitales (ecommerce, plataformas en línea)
- Transporte terrestre local y servicios logísticos
- Empresas medianas de sectores industriales relevantes

¿Por qué son importantes?

Aunque su interrupción no afecte directamente a la seguridad nacional, puede causar pérdidas económicas relevantes, afectar a cadenas de suministro o generar efectos en cascada.

Directiva NIS2 aplicada a entornos OT

Diferencias clave entre las dos

Aspecto	Entidades Esenciales	Entidades Importantes
Supervisión	Proactiva: la autoridad puede inspeccionar sin aviso	Reactiva: solo tras incidentes o denuncias
Sanciones máximas	Hasta 10 millones € o 2% del volumen de negocio anual	Hasta 7 millones € o 1,4% del volumen de negocio anual
Nivel de exigencia	Mayor (más controles, inspecciones, exigencia documental)	Elevado, pero menos riguroso en seguimiento directo
Obligaciones NIS2	Completas: gobernanza, continuidad, notificación, etc.	Las mismas, pero con distinta intensidad de supervisión
Impacto esperado de un incidente	Grave y sistémico	Relevante pero limitado

Directiva NIS2 aplicada a entornos OT

Criterios adicionales

Además del sector, NIS2 incluye una **cláusula de umbral**:

*Organizaciones con más de **50 empleados** o más de **10 millones € de facturación anual** deben evaluarse como posibles entidades esenciales o importantes (según su sector).*

Excepciones: algunas entidades públicas o infraestructuras específicas pueden clasificarse como esenciales, aunque no cumplan esos umbrales.

Directiva NIS2 aplicada a entornos OT

¿Desde cuando aplica?

- La Directiva entró en vigor en enero de 2023.
- Los estados miembros deben transponerla a su legislación nacional antes del 17 de octubre de 2024.
- En España se espera que sustituya parcialmente a la actual Ley 43/2010 y complemente la Ley PIC (8/2011).

¿Qué obliga a cumplir?

- Evaluación de riesgos en activos OT.
- Política de ciberseguridad OT aprobada por la dirección.
- Protección contra accesos no autorizados en redes industriales.
- Capacitación del personal de planta y mantenimiento.
- Notificación de incidentes OT significativos (fallos, ataques, malware).
- Planes de continuidad y recuperación OT (resiliencia operacional).

Directiva NIS2 aplicada a entornos OT

¿Cómo adecuarse?

A nivel **procedimental**:

- Crear o adaptar una **política de ciberseguridad OT**.
- Establecer procesos de **notificación de incidentes** (24h inicial, 72h actualización).
- Integrar la gestión de riesgos OT en el SGSI o plan de continuidad.
- Designar roles de **responsable de Ciber OT**, con autoridad real.

• A nivel **tecnológico**:

- Segmentar redes OT y proteger puntos de acceso.
- Usar sistemas de detección de intrusiones (IDS/IPS) en OT.
- Supervisar logs, conexiones, y tráfico anómalo.
- Implementar actualizaciones seguras de firmware/software industrial.
- Revisar proveedores críticos (supply chain).

Directiva NIS2 aplicada a entornos OT

Consecuencias del no cumplimiento

Sanciones económicas:

- Hasta **10 millones € o el 2% de facturación** (esenciales)
- Hasta **7 millones € o el 1,4%** (importantes)

Otras consecuencias:

- Suspensión de actividades o licencias
- Responsabilidad personal de la dirección
- Daño reputacional grave

Directiva NIS2 aplicada a entornos OT

Roles y responsabilidades

Rol	Responsabilidad
Alta dirección	Aprobación y supervisión de políticas.
Responsable de ciberseguridad (CISO)	Coordinación de la estrategia general.
Responsable de OT / planta	Implementación técnica y operativa.
CSIRT interno / externo	Respuesta ante incidentes.
Departamento legal / compliance	Gestión de informes y relación con la autoridad.

Directiva NIS2 aplicada a entornos OT

- **Gobernanza:** NIS2 refuerza la gobernanza corporativa en ciberseguridad, obligando a la alta dirección a implicarse activamente en la gestión de riesgos y cumplimiento de obligaciones legales.
- **Responsabilidad de la alta dirección:** La alta dirección es legalmente responsable de la aprobación de políticas de seguridad, la asignación de recursos y la supervisión de su cumplimiento. Puede ser sancionada por negligencia.
- **Política de Ciberseguridad:** Las organizaciones deben disponer de una política formal que cubra todo el ciclo de vida de la seguridad: prevención, detección, respuesta y recuperación. Debe estar aprobada al más alto nivel.

Directiva NIS2 aplicada a entornos OT

- **Gobernanza en sistemas OT:** La gobernanza debe extenderse a sistemas industriales. Esto implica integrar OT en el SGSI, identificar responsables OT y establecer mecanismos de reporte técnico y ejecutivo.
- **Cultura organizativa:** NIS2 exige fomentar una cultura de ciberseguridad en todos los niveles: desde operarios en planta hasta la dirección, incluyendo formación, sensibilización y políticas claras.
- **Gestión de Riesgos:** Las entidades deben implementar un proceso continuo de identificación, evaluación y mitigación de riesgos que puedan afectar a la red, los sistemas o los servicios esenciales.

Directiva NIS2 aplicada a entornos OT

- **Activos Críticos:** Se debe mantener un inventario actualizado de activos críticos (IT y OT), clasificarlos por importancia y aplicarles controles de seguridad según su criticidad.
- **Análisis de Riesgos:** El análisis debe incluir amenazas cibernéticas, fallos técnicos, errores humanos y dependencias externas (proveedores). Recomendado: usar metodologías como ISO 31000, MAGERIT o EBIOS.
- **Controles mínimos exigidos:** La directiva menciona explícitamente controles como: autenticación multifactor, cifrado, segmentación de redes, control de accesos, detección de anomalías y continuidad operativa.

Directiva NIS2 aplicada a entornos OT

- **Auditorías y Evaluaciones:** Las entidades deben someterse a auditorías periódicas. Las esenciales estarán sujetas a inspecciones proactivas, mientras que las importantes serán supervisadas tras incidentes.
- **Gestión de Proveedores:** Se exige revisar los riesgos asociados a terceros, especialmente IT y OT. Esto incluye cláusulas contractuales, evaluaciones de seguridad y controles en la cadena de suministro.
- **Pruebas y simulacros:** Las organizaciones deben realizar pruebas periódicas de sus sistemas de seguridad, incluyendo simulacros de ataque, para evaluar la efectividad de sus controles y procedimientos.

Directiva NIS2 aplicada a entornos OT

- **Plan de continuidad y recuperación:** Debe existir un plan documentado que contemple incidentes cibernéticos. En entornos OT, esto implica escenarios de parada controlada, degradación funcional y recuperación segura.
- **Notificación de Incidentes:** La notificación debe realizarse al CSIRT nacional o autoridad competente en tres fases: aviso inicial (24h), actualización (72h) e informe final (1 mes o antes).
- **Qué se considera incidente:** Cualquier evento que comprometa la disponibilidad, integridad o confidencialidad de redes, sistemas o datos. Ejemplos: ransomware, brechas de datos, denegaciones de servicio, sabotaje OT.

Directiva NIS2 aplicada a entornos OT

- **Canales de notificación:** Deben establecerse canales internos de detección y reporte, así como mecanismos seguros y trazables para comunicar con las autoridades.
- **Procedimiento interno:** Cada organización debe documentar su procedimiento de respuesta y notificación, con roles definidos, criterios de gravedad y tiempos máximos por tipo de incidente.
- **Obligaciones para OT:** En entornos industriales, los incidentes que afecten a procesos físicos, seguridad operativa o disponibilidad de planta también deben notificarse bajo NIS2.

Directiva NIS2 aplicada a entornos OT

- **Procedimiento interno:** Cada organización debe documentar su procedimiento de respuesta y notificación, con roles definidos, criterios de gravedad y tiempos máximos por tipo de incidente.
- **Resumen Final:** La gobernanza, la gestión de riesgos y la notificación de incidentes son pilares clave de NIS2. Su cumplimiento implica cambios organizativos, técnicos y culturales.